LEZIONE 03

Quale aggiornamento fare per primo

Le vulnerabilità escono a migliaia e da solo non le correggi tutte. Ci sono due elenchi gratuiti che dicono quali vengono usate davvero: parti da quelli.

A COLPO D'OCCHIO

È nel catalogo KEV	viene già sfruttata in attacchi reali	**subito**
EPSS alto	è probabile che venga sfruttata a breve	**questa settimana**
Tutto il resto	anche con punteggio CVSS alto	**giro mensile**

Dare priorità: EPSS e CISA KEV

Le vulnerabilità sono migliaia: non si può patchare tutto subito. Due strumenti aiutano a **dare priorità**:

- **EPSS** (*Exploit Prediction Scoring System*): stima la **probabilità** che una vulnerabilità **venga sfruttata** a breve (0–100%). Risponde a "quanto è probabile che serva davvero?".
- **CISA KEV** (*Known Exploited Vulnerabilities*): un **catalogo** delle vulnerabilità **note per essere già attivamente sfruttate** in attacchi reali. Se una CVE è nel KEV, va patchata **subito**.

> Regola pratica di priorità: **CVE nel KEV** → urgenza massima; poi **EPSS alto** + **CVSS alto**. CVSS da solo non basta: una falla "critica" mai sfruttata è meno urgente di una "media" sfruttata in massa.

Un caso vero: il bollettino Microsoft del 14 marzo 2023

Quel martedì Microsoft ha pubblicato più di ottanta correzioni. Fra queste, tre falle da 9.8 e una da 4.4. Guardando solo il punteggio l'ordine è ovvio: prima le tre critiche, la 4.4 quando capita. Tre anni dopo, i due elenchi di questa lezione dicono un'altra cosa.

CVE	Cosa	CVSS	Nel KEV	EPSS oggi
CVE-2023-23397	Outlook, la falla della lezione 2	9.8	sì, dal 14 marzo 2023	97%
CVE-2023-24880	SmartScreen, l'avviso di Windows sui file scaricati	4.4	sì, dal 14 marzo 2023	78%
CVE-2023-23392	HTTP.sys, il servizio web di Windows Server	9.8	no	1,7%
CVE-2023-21708	RPC, le chiamate fra programmi in rete	9.8	no	1,5%

Valori letti il 19 ottobre 2026 su cisa.gov e first.org.

Le due che gli attaccanti usano davvero sono la 9.8 di Outlook e la 4.4. Quella da 4.4 serviva a far scaricare un file senza che Windows mostrasse l'avviso, e un gruppo ransomware la stava già usando il giorno in cui è uscita la correzione. Le altre due 9.8 sono rimaste sulla carta: in tre anni nessuno le ha viste sfruttate, e l'EPSS le dà sotto il 2%.

Chi quel giorno aveva una sola finestra per aggiornare doveva fare Outlook e SmartScreen. Chi ha seguito il punteggio ha fatto Outlook, HTTP.sys e RPC, e ha lasciato aperta la porta da cui passava il ransomware.

Dove si guardano

- **Catalogo KEV** (cisa.gov/known-exploited-vulnerabilities-catalog): è un elenco scaricabile anche in CSV. Per ogni voce c'è il fornitore, il prodotto e la data entro cui le agenzie americane devono aver corretto. Quella data per te è un'indicazione di urgenza.
- **EPSS** (first.org/epss): cerchi il CVE e ti dà una probabilità e un percentile. Un percentile del 95% significa che quella vulnerabilità è fra il 5% più probabile che venga sfruttata nei prossimi trenta giorni. Per la falla di Outlook della lezione 2 (CVE-2023-23397) oggi vale 97%, al 99,9° percentile: quasi certamente qualcuno la sta usando, dopo tre anni. La maggior parte dei CVE sta sotto l'1%: gravi sulla carta, mai sfruttati.

Tutti e due sono gratis e non richiedono registrazione.

Un giro mensile che regge, da soli

Un'ora al mese, sempre lo stesso giorno:

1. Apri il catalogo KEV e filtra per i fornitori che hai in azienda (dal tuo elenco della lezione 2). Guardi solo le voci nuove dall'ultimo giro. Se hai lo script di questa lezione, apri `da_fare.csv` e salta al punto 2.
2. Per ogni voce controlli se la versione colpita è la tua. Se sì, aggiornamento in settimana.
3. Per gli avvisi arrivati nel mese che non sono nel KEV, guardi l'EPSS. Sopra il 50%, in settimana. Sotto, nel giro successivo.

4. Segni sul tuo elenco la data dell'aggiornamento e se la macchina è stata riavviata.

Gli errori che vedo più spesso

- **Aggiornare per gravità.** È il modo più naturale e il meno utile. Si passano le giornate su cose critiche che nessuno sfrutta e si lascia indietro quella media che tutti sfruttano.
- **Aspettare la finestra di manutenzione** per tutto. Per un apparato esposto nel KEV la finestra è stasera.
- **Non riavviare.** L'ho detto nella lezione 2 e lo ripeto perché lo vedo in continuazione.
- **Aggiornare senza una via di ritorno.** Prima di aggiornare un apparato di rete, salva la configurazione. Prima di aggiornare un server, uno snapshot se è virtuale.

CON L'AI, PER QUESTA LEZIONE

Uso 3 di 12 · Far crescere lo strumento della lezione 2. Nella lezione 2 ti sei fatto scrivere due cose: l'elenco dei CPE della tua azienda e uno script che ogni lunedì chiede all'NVD i CVE della settimana che riguardano quei CPE. Oggi quello script impara a dirti anche l'ordine. Il catalogo KEV si scarica come CSV (`cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.csv`) e l'EPSS ha un'interfaccia pubblica che accetta più CVE in una richiesta sola (`api.first.org/data/v1/epss?cve=...`). Tutti e due senza chiave. E stavolta il confronto è sul codice CVE, che è esatto, non sul nome del prodotto.

Primo passo: una colonna in più. Nel file dei CPE aggiungi a ogni riga, dopo un punto e virgola, se quell'apparato è raggiungibile da internet (`si` o `no`). Se per qualche riga non lo sai, è la prima cosa da scoprire: un apparato esposto nel KEV è la riga che va in cima.

Secondo passo: lo script. Incolla quello della lezione 2 e chiedi:

> Questo è il mio script che legge un CPE per riga e interroga l'NVD. Modificalo così: il file dei CPE ha ora una seconda colonna, separata da punto e virgola, con `si` o `no` se l'apparato è esposto a internet. Per ogni CVE trovato: scarica una volta sola il CSV del catalogo KEV di CISA e segna se il CVE c'è e la data entro cui va corretto; chiedi l'EPSS all'API di FIRST passando tutti i CVE in una richiesta sola e segna probabilità e percentile. Scrivi un file `da_fare.csv` con una riga per CVE (codice, prodotto, esposto, KEV, scadenza KEV, EPSS, CVSS) ordinato: prima i KEV su apparati esposti, poi gli altri KEV, poi tutto il resto per EPSS decrescente. In fondo stampa quante righe hai scartato e perché. Se un servizio non risponde, dillo invece di saltare in silenzio.

Lo provi una volta con CVE-2023-23397 messo in lista a mano: deve uscire KEV sì, scadenza 4 aprile 2023, EPSS intorno al 97%. Se esce senza KEV, lo script legge male il CSV e da quel momento ti dirà sempre che va tutto bene.

Terzo passo: l'arretrato. Lo script guarda gli ultimi sette giorni, ma le falle del caso di questa lezione hanno tre anni e qualcuno le sfrutta ancora. La prima volta va fatto girare all'indietro:

> Aggiungi un parametro per la finestra di giorni, con 7 come valore normale. La prima esecuzione la faccio su 1095 giorni: rispetta il limite dell'NVD senza chiave (cinque richieste ogni trenta secondi) e, visto che l'API accetta al massimo 120 giorni per richiesta, spezza da solo l'intervallo. Alla fine dimmi quanti CVE hai trovato in tutto e quanti sono nel KEV.

Quel primo `da_fare.csv` sarà lungo, ed è l'elenco vero degli aggiornamenti arretrati: le righe KEV in cima sono quelle da fare questa settimana, il resto segue l'ordine della lezione. Da quel lunedì il giro mensile diventa leggere un file di dieci righe già in ordine. L'ordine lo decidono CISA e FIRST con i loro dati, non l'assistente: lui ha scritto il programma, e il programma lo hai provato tu su un CVE che conosci.

DA FARE

Lunedì mattina, se sei l'unico informatico

1. Controlla se il CVE è nel catalogo KEV di CISA (cisa.gov/known-exploited-vulnerabilities-catalog). Se c'è, quell'aggiornamento passa davanti a tutto. ☐
2. Per gli altri guarda il punteggio EPSS su first.org/epss. Una probabilità alta conta più di un punteggio CVSS alto. ☐
3. Scrivi la regola su un foglio e attaccalo al monitor: KEV subito, EPSS alto in settimana, il resto nel giro mensile. ☐

Glossario

Le sigle nuove di questa lezione, con due righe ciascuna: la prima per capirsi, la seconda per capire. Poi, in breve, quelle delle lezioni precedenti.

KEV NUOVA — Il catalogo delle vulnerabilità che vengono già sfruttate in attacchi reali, tenuto da CISA (Known Exploited Vulnerabilities). *Per capirla meglio:* Se una vulnerabilità è nel KEV, non è più una questione di probabilità: qualcuno la usa. Per questo passa davanti a tutto. È un CSV scaricabile, con fornitore, prodotto e la data entro cui le agenzie americane devono aver corretto.

CISA NUOVA — L'agenzia americana per la sicurezza informatica e delle infrastrutture (Cybersecurity and Infrastructure Security Agency). *Per capirla meglio:* Pubblica il catalogo KEV e avvisi su campagne in corso. È americana, ma le vulnerabilità sono le stesse ovunque: il suo catalogo vale anche per un'azienda toscana.

FIRST NUOVA — L'associazione mondiale delle squadre di risposta agli incidenti, che calcola e pubblica l'EPSS (Forum of Incident Response and Security Teams). *Per capirla meglio:* Mette insieme CERT e squadre di sicurezza di tutto il mondo. Per te conta per una cosa sola: è la fonte dell'EPSS, gratuita e con un'API.

CSV NUOVA — Un file di testo con i dati in colonne separate da virgole (Comma-Separated Values). Si apre con un foglio di calcolo. *Per capirla meglio:* È il formato in cui scarichi il catalogo KEV e in cui tieni l'inventario: semplice, leggibile da qualsiasi programma, senza bisogno di software particolare. Lo script della lezione 3 legge e scrive CSV.

Dalle lezioni precedenti (la spiegazione completa è nella lezione in cui sono comparse):

CIA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *(lezione 1)*

ransomware — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *(lezione 1)*

DDoS — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *(lezione 1)*

HTTPS — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *(lezione 1)*

PLC — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *(lezione 1)*

IBAN — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *(lezione 1)*

AI — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *(lezione 1)*

CVE — Il codice univoco di una vulnerabilità nota, nel formato CVE-anno-numero (Common Vulnerabilities and Exposures). *(lezione 2)*

CPE — Il nome standard di un prodotto e di una versione, usato dall'NVD per dire cosa colpisca un CVE (Common Platform Enumeration). *(lezione 2)*

CWE — La categoria di una debolezza del software, per esempio «SQL injection» (Common Weakness Enumeration). *(lezione 2)*

CVSS — Il punteggio di gravità di una vulnerabilità, da 0 a 10 (Common Vulnerability Scoring System). *(lezione 2)*

NVD — La banca dati pubblica dei CVE, gestita dal NIST americano (National Vulnerability Database). *(lezione 2)*

EOL — Fine del supporto di un prodotto: il produttore non pubblica più correzioni, nemmeno di sicurezza (End Of Life). *(lezione 2)*

PoC — Il codice, o la procedura, che dimostra che una falla si può sfruttare davvero (Proof of Concept). *(lezione 2)*

NIST — L'ente americano degli standard (National Institute of Standards and Technology). Gestisce l'NVD e pubblica le linee guida più usate. *(lezione 2)*

CNA — Gli enti autorizzati ad assegnare i codici CVE: grandi produttori, CERT nazionali, ricercatori accreditati (CVE Numbering Authority). *(lezione 2)*

MITRE — L'organizzazione americana senza scopo di lucro che coordina i CVE e gestisce ATT&CK. *(lezione 2)*

CERT — Una squadra che risponde agli incidenti informatici, nazionale o di settore (Computer Emergency Response Team). *(lezione 2)*

EPSS — Una stima, in percentuale, della probabilità che una vulnerabilità venga sfruttata nei prossimi trenta giorni (Exploit Prediction Scoring System). *(lezione 2)*

AV, AC, PR, UI — Le quattro lettere principali del vettore CVSS: da dove si attacca, quanto è difficile, se servono privilegi, se serve un'azione dell'utente. *(lezione 2)*

SQL — Il linguaggio con cui si interrogano le banche dati (Structured Query Language). *(lezione 2)*

XSS — Un difetto di un sito che permette di far eseguire del codice nel browser di chi lo visita (Cross-Site Scripting). *(lezione 2)*

VPN — Un collegamento cifrato da fuori verso la rete aziendale, come se si fosse in ufficio (Virtual Private Network). *(lezione 2)*

NAS — Un disco di rete condiviso, spesso usato per i file e per i backup (Network Attached Storage). *(lezione 2)*

API — Un modo per far parlare due programmi fra loro, senza passare da una pagina web (Application Programming Interface). *(lezione 2)*

Ing. Alessandro Manneschi
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
github.com/alevento/sicurezza-per-chi-e-solo
Licenza CC BY-NC-SA 4.0